记一次渗透测试

信息收集-越权

目　录

一、　信息收集.....1
子域名收集.....1
存活探测.....1
二、　越权.....2
越权一.....2
越权二.....4

文档摘要

文档编号	
文档名称	
文档版本	V1.0
文档作者	
参与编写	
文档审核	
文档分类标识	
文档状态	☐草案 ☐修订中 ☑试用 ☐正式发布 ☐废止
首次编写日期	
文档属性	☐内部保密 ☑内部公开 ☐外部公开
发布范围	

一、 信息收集

子域名收集

使用 subfinder 进行子域名收集

语法：subfinder.exe -d xx.com -all -o qq1.txt -v

//结合自己渗透经验，多渠道收集子域名，汇总去重。

存活探测

使用 httpx 批量探测域名常见端口存活

语法：httpx.exe -l qq1.txt -cdn -no-fallback -random-agent -content-length -follow-redirects -tech-detect -retries 2 -status-code -stats -threads 8000 -title -tls-grab -unsafe -websocket -ports 端口列表 -o qqres.txt

接下来就是根据自己此时的状态，随缘或仔细访问每一个站点

二、 越权

越权一

简要描述：其中某个站点存在越权，用户可以通过修改注册审批状态，来获取一定的权限，可对后台接口拥有访问权限。

提交注册申请，请求包如下


```
{
  "user":{
    "name":"
    "phone":
    "email":"
    "remark":"t
    "status":"1
  },
  "roleIds":[
  ]
}
```


其中 status 代表该申请审批状态

Fuzzing：1 表示审批中，2 表示确认审批，3 表示审批拒绝

修改 status 为 2，刷新页面


```
    "status":"2"
  },
  "roleIds":[
  ]
```


此时提示没有权限（其实是已经绕过审批，只是还没有赋予权限）（不然就是申请已提交，请等待审批）

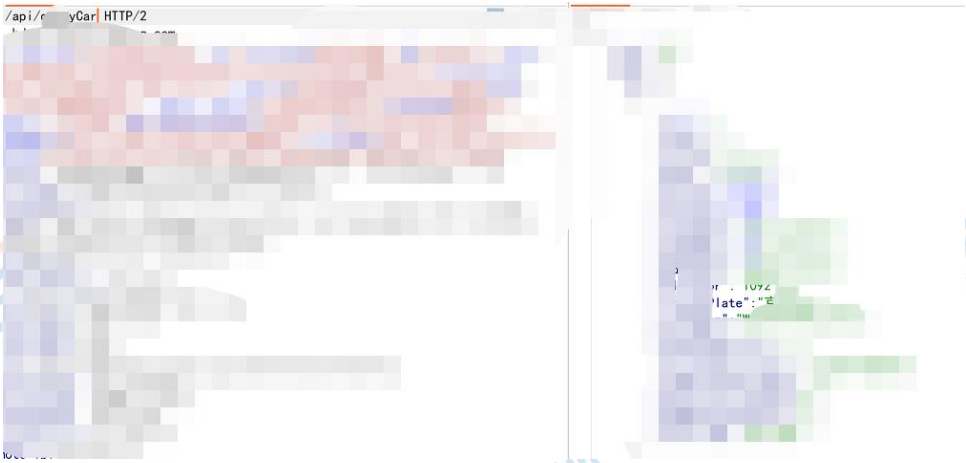
警告：没有权限

请联系管理员添加相应的操作权限

然后查看历史包，有个 api/xxxxUser 的请求，返回了用户敏感数据

此时的现状是，浏览器页面提示没有权限，但实际上可以通过更改相关请求 url 中的接口来获取系统后台敏感数据

如下：

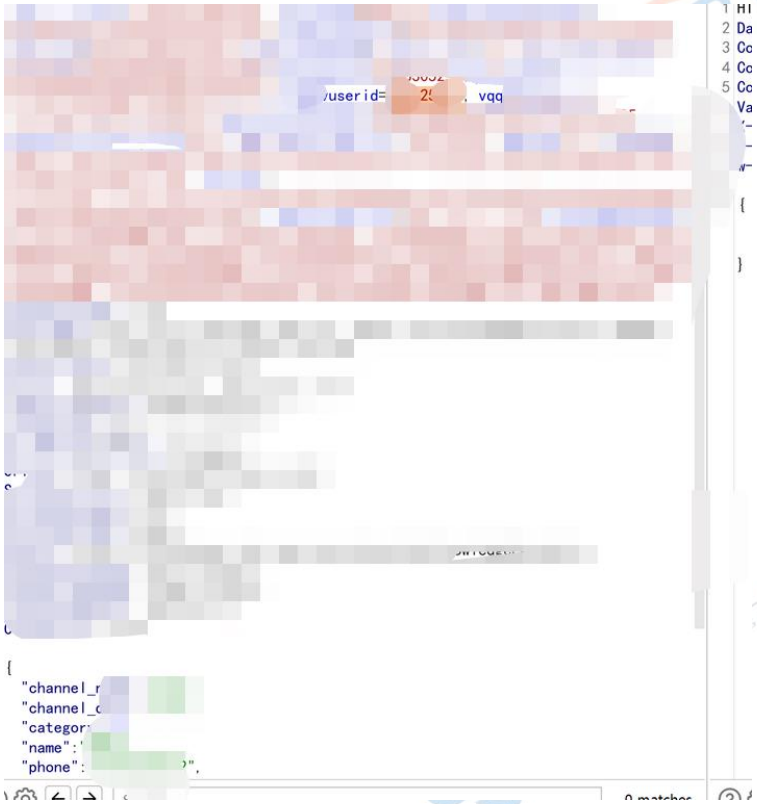


同时也可以通过 burp 插件 BurpJSLinkFinder 来辅助获取后台接口 url 地址

越权二

简要描述：创建相关资源时，单个账号只可以创建一次。在创建资源的请求包中，可以通过更改 cookie 中的 userid 来越权给他人创建资源，并且创建的资源信息是同步的。

影响面一：可对其他用户进行恶意创建，阻止其他用户正常进行业务操作。

影响面二：“广告位招租”

修改 xxxuserid 即可（测试时需注意，用自己的账号 A 测试自己的账号 B，避免影响业务数据）